TEAM 29 – CYBER DEFENSE REPORT

ICDC 2026 – CDC Public Transportation Scenario

This document consolidates all findings, hardening actions, deployment steps, and vulnerability assessments performed on Team 29 systems. It includes both the Ticketing Machine (Windows Infrastructure) and the Public Website (Linux Infrastructure) security assessments.

SECTION I – ACTIVE DIRECTORY HARDENING REPORT

Domain: team29.isucdc.com

Primary Domain Controller: Windows Server (tickets.team29.isucdc.com)

1. Security Policy Enforcement

Active Directory hardening was performed through Group Policy Management → Default Domain Controllers Policy → Computer Configuration → Policies → Windows Settings → Security Settings → Local Policies → Security Options.

The following domain controller security configurations were implemented:

Domain controller: LDAP server signing requirements → Require signing

Enforces LDAP integrity protection and prevents unsigned/simple bind attacks, mitigating credential interception and man-in-the-middle attacks.

Network security: LAN Manager authentication level → Send NTLMv2 response only. Refuse LM & NTLM

Disables legacy LM and NTLM authentication protocols, enforcing NTLMv2 exclusively. This mitigates downgrade attacks, weak hash exposure, and legacy authentication abuse.

Network security: Do not store LAN Manager hash value → Enabled

Prevents storage of weak LM password hashes in Active Directory, reducing susceptibility to offline hash cracking.

Network access: Do not allow anonymous enumeration of SAM accounts → Enabled

Network access: Do not allow anonymous enumeration of SAM accounts and shares → Enabled

These configurations prevent null session enumeration of domain users and shared resources, reducing reconnaissance vectors.

Network security: Configure encryption types allowed for Kerberos → AES128_HMAC_SHA1 and AES256_HMAC_SHA1 only

RC4 and DES encryption were disabled. Enforcing AES-only Kerberos encryption mitigates Kerberoasting attacks that rely on weaker encryption types.

2. Privilege and Logon Rights Hardening

User rights assignments were modified to reduce lateral movement and privilege escalation risk:

Allow log on through Remote Desktop Services → Domain Admins only

Restricts interactive remote access to privileged administrators.

Deny log on through Remote Desktop Services → Domain Users, Guests

Explicit denial prevents standard users from attempting RDP-based access.

Add workstations to domain → Authenticated Users removed

Prevents arbitrary domain-joined machine creation by standard users, limiting machine account abuse.

3. Service Reduction on Domain Controller

Unnecessary services were disabled to reduce attack surface:

Print Spooler service disable

-Stop-Service Spooler -Force

-Set-Service Spooler -StartupType Disabled

The Print Spooler has historically been exploited through vulnerabilities such as PrintNightmare (CVE-2021-34527). Disabling it on the domain controller eliminates this attack vector.

4. Audit and Monitoring Controls

Advanced audit policies were enabled to monitor:

-Logon and logoff events

-Privilege use

-Object access

-Account management

This ensures visibility into authentication attempts, privilege changes, and directory modifications during competition operations.

5. Security Posture Summary

Active Directory has been hardened against:

-NTLM downgrade attacks

-LM hash cracking

-Kerberoasting using weak encryption

-LDAP unsigned binds

-Anonymous enumeration

-RDP-based lateral movement

-Print Spooler exploitation

-Unauthorized workstation domain joins

The domain controller is operating under enforced cryptographic standards, reduced attack surface, and restricted administrative access. Policy propagation is subject to normal Group Policy refresh intervals (approximately 5 minutes for domain controllers), after which scoring and compliance systems reflect updated configurations.

The Active Directory environment is secured and prepared for attack-phase competition conditions.

SECTION II – MANAGEMENT BACKEND APPLICATION SECURITY REVIEW

System: mgmt.team29.isucdc.com
Platform: AlmaLinux 8.4
Application Framework: Flask
Directory Services Integration: Active Directory

1. System Overview

The Management Backend (mgmt.team29.isucdc.com) operates as the central transit management API within the CDC public transportation infrastructure. It runs on AlmaLinux 8.4 and hosts a Flask-based Python application on port 5000.

This backend provides core functionality for authentication, ticket processing, vehicle fleet management, route coordination, and payment information handling. It is consumed by the Admin UI, Public Website, a hidden vehicle simulator, and the IScorE scoring system. Because it acts as the authoritative control plane for transit operations, compromise of this system would directly impact service availability and scoring integrity.

2. Application Architecture Assessment

Initial review focused on understanding the internal application structure. The backend consists of modular components responsible for authentication, LDAP integration, vehicle control, ticket management, payment processing, and routing configuration. Security decorators enforce access control via @require_auth and @require_admin mechanisms.

Early in the assessment, we identified that the Werkzeug debugger was enabled in production. This configuration exposed stack traces, internal variables, source code paths, and potentially interactive console access if triggered. Debug mode was immediately disabled in the application configuration to eliminate information disclosure and remote code execution risk.

3. Cross-Origin Resource Sharing (CORS) Misconfiguration

A critical CORS misconfiguration was discovered during review of the application initialization logic. The backend was configured with a wildcard origin policy, allowing any domain to send cross-origin requests to the API.

This configuration enabled cross-site request forgery and session abuse scenarios, where malicious third-party websites could trigger authenticated requests from a victim's browser. Because the backend relies on session-based authentication, unrestricted CORS significantly increased exploitation risk.

The policy was corrected to explicitly allow only legitimate domains:

- admin.team29.isucdc.com
- www.team29.isucdc.com
- tickets.team29.isucdc.com:5000

Credential support was enabled to properly handle session cookies. This change does not impact direct server-to-server API calls such as the vehicle simulator, as CORS restrictions apply only to browser-enforced cross-origin requests.

4. Authentication Logic and Administrator Mapping

During review of the authentication flow, we discovered incorrect mapping of Active Directory group membership to application-level administrator privileges. Users belonging to the "Transit Admins" AD group were not consistently assigned session['is_admin'] = True, causing legitimate administrators to lack proper permissions.

The login flow was traced from LDAP validation to session creation. The logic in auth.py was corrected to accurately evaluate AD group membership before setting administrative session

flags. This ensures that the @require_admin decorator functions correctly and enforces role-based access control as intended.

5. LDAP Injection Vulnerabilities

Multiple LDAP injection vulnerabilities were identified in ldap.py. Several functions constructed LDAP queries by directly interpolating user-supplied input into filter strings without sanitization. Affected functions included:

- ldap_exists()
- create_ldap_user()
- add_to_group()
- change_ldap_password()
- check_group_membership()

These vulnerabilities could allow attackers to manipulate LDAP filters, bypass authentication, enumerate users, or escalate privileges.

All LDAP queries were refactored to sanitize user input using the ldap3 escape_filter_chars() function. This ensures that special LDAP filter characters are escaped before query execution, preventing injection attacks while preserving legitimate authentication functionality.

6. Privilege Escalation via Automatic Admin Assignment

A critical privilege escalation vulnerability was identified in the create_ldap_user() function. Newly registered users were automatically added to the “Transit Admins” group through an unconditional group assignment call.

This allowed any attacker to register a new account and instantly gain administrative control over the entire transit system, including vehicle control, route modification, and payment data access.

The automatic admin group assignment was removed. New registrations now create standard user accounts. Administrative privileges must be granted manually through controlled procedures. This change restored the integrity of the access control model.

7. Vehicle API Authorization Bypass

The /vehicles/<vehicle_id> POST endpoint originally lacked authentication and authorization checks. Any unauthenticated attacker could modify vehicle status, disable buses, trigger service disruption flags, and affect scoring.

The endpoint was secured by applying the @require_admin decorator. The updated logic enforces:

Valid authenticated session

Verified membership in Transit Admins AD group

Administrative authorization prior to state modification

This mitigation eliminated unauthenticated service disruption attacks.

8. Payment API Stability and Access Control

The GET /payment-info/ endpoint contained a null dereference vulnerability. If payment information did not exist for a user, the endpoint attempted to call to_dict() on a None object, resulting in application crashes.
Null checks were implemented to return a 404 response when payment data is absent. This prevents service instability and improves error handling.
The endpoint correctly enforces session-based authentication and retrieves payment data based solely on the authenticated session username. It does not accept arbitrary username parameters, preventing horizontal privilege escalation.

9. Ticket Deletion Authorization Bypass
In tickets.py, the DELETE /tickets/delete/<ticket_id> endpoint lacked ownership verification. Authenticated users could delete other users' tickets by enumerating ticket IDs.
Ownership validation was added to ensure that a ticket exists and belongs to the authenticated user before deletion is permitted. This aligns deletion logic with other ticket operations and restores consistent authorization enforcement.

10. Route Management Logic Correction
A logic flaw was identified in route update functionality. The code incorrectly validated the presence of the name parameter instead of the type parameter when updating route type values.
The conditional logic was corrected to properly validate and update the route type field. While not a security issue, this fix ensures correct operational behavior for transit administrators managing route configurations.

11. Management Backend Application Status
The Management Backend has undergone extensive application-layer security remediation. Critical vulnerabilities including debug exposure, CORS misconfiguration, LDAP injection, privilege escalation via auto-admin assignment, authorization bypass in vehicle control, ticket deletion flaws, and stability issues have been resolved.
Role-based access control now properly reflects Active Directory group membership, injection risks have been mitigated, and administrative endpoints are protected with enforced authentication and authorization checks.
The backend is now aligned with secure development best practices and prepared for competition attack-phase operations.

SECTION III – MANAGEMENT BACKEND HARDENING REPORT

System: management.team29.isucdc.com
Platform: Linux Server
Assessment Platform: Kali Linux 2025.1c
Virtualization Platform: Proxmox VE

1. Kali Linux Deployment and Network Configuration

A dedicated Kali Linux virtual machine was deployed in Proxmox VE to serve as the internal security assessment platform for Team 29 infrastructure. The VM was provisioned with four CPU cores (host type), 4GB RAM, and attached to the competition network bridge (compnet). Kali Linux 2025.1c was installed using the graphical installer.
The system hostname was configured as “Kali” and joined to the domain team29.isucdc.com to maintain naming consistency across the competition environment.

During initial deployment, the VM received an IP address on subnet 10.42.0.189, which prevented communication with the management backend located in the 52.135.80.0/24 network. This misconfiguration was corrected by assigning a static IP address (52.135.80.105) using NetworkManager. Once placed on the correct subnet, full network connectivity with competition systems was restored.

2. Security Assessment and Port Enumeration
A comprehensive network scan was conducted against the management backend at 52.135.80.30 using full-port enumeration and service detection techniques with nmap.

The scan identified four open services:
- Port 22 – SSH running OpenSSH 8.0
- Port 111 – RPCbind
- Port 3306 – MySQL/MariaDB
- Port 5000 – Backend management application running on Werkzeug development server.

Based on competition requirements, only SSH (port 22) and the management application (port 5000) were required for operational functionality. RPCbind and externally exposed MariaDB services were unnecessary and increased the attack surface.

3. Service Hardening and Exposure Reduction
To eliminate unnecessary exposure, port 111 was closed by stopping, disabling, and masking both the rpcbind service and its associated socket using systemd. This prevented RPC-related services from restarting or being triggered by dependent processes.
For port 3306, MariaDB was reconfigured to listen only on localhost by adding the directive:

bind-address = 127.0.0.1

This preserved internal database functionality for the backend application while preventing external connections from the competition network.

SSH configuration was hardened to reduce brute-force and privilege escalation risk. The MaxAuthTries parameter was set to 3, limiting authentication attempts per session. PermitRootLogin was set to “no,” preventing direct root access via SSH. Since the cdc user retains sudo privileges, administrative capabilities remain intact while eliminating direct root login exposure.

4. Validation and Verification
Post-hardening validation scans confirmed that only ports 22 and 5000 remained accessible from the network. A targeted vulnerability scan using nmap vulnerability scripts did not identify any critical exploitable issues in the remaining services.
The attack surface was effectively reduced by 50%, eliminating two externally exposed services without impacting required competition functionality. Administrative access remains operational, the backend application continues to function normally, and unnecessary network exposures have been removed.

5. Management Backend Status
The management backend system is now hardened according to competition operational requirements. Unnecessary services have been disabled, database exposure eliminated, SSH strengthened, and validation scans confirm reduced risk.
The system remains functional, compliant, and prepared for the competition attack phase.

SECTION IV – TICKETING MACHINE REPORT

System: tickets.team29.isucdc.com
Platform: Windows Server 2019
Application Framework: .NET 8 ASP.NET Core Web API

1. System Overview
The Ticketing Machine functions as the backend ticket issuance and validation service for CDC's public transportation infrastructure. The system generates RSA256 cryptographically signed transit tickets, validates ticket authenticity at reader endpoints, and ensures tamper-proof ticket data integrity.
The application operates as a .NET 8 ASP.NET Core Web API hosted on port 5000. It integrates with Active Directory to obtain an X.509 certificate from the domain Certificate Authority. The private key stored in the LocalMachine certificate store is used for RSA256 digital signing, ensuring cryptographic authenticity of issued tickets.
Service availability is mission-critical. Failure in certificate access or signing configuration would prevent ticket issuance and disrupt public transportation operations.

2. Deployment and Configuration
Initial assessment revealed default Administrator credentials and application source code located in the Administrator desktop directory. The application was successfully compiled and tested using dotnet build and dotnet run, confirming functionality and API responsiveness.
For production readiness, the application was published in Release mode to C:\Deploy\Tickets. Publishing in Release configuration optimized performance, ensured scenario-required artifacts were deployed, and prepared the system for automated startup.
A scheduled task was configured to run the service at system boot under the SYSTEM account with highest privileges. The task includes automatic restart policies to ensure resilience in case of service interruption. Post-deployment verification confirmed the process was active and port 5000 was listening.

3. Network Hardening and Access Control

Credential hardening was performed immediately by replacing default Administrator credentials with strong passphrases.

Windows Defender Firewall was enabled across all profiles with a default-deny posture. Only required ports were opened:

- 3389 (RDP)
- 5000 (Ticketing API)

All other inbound connections are blocked. This minimized the exposed attack surface and limited remote exploitation vectors.

4. Certificate Authority Integration

Connectivity to the Active Directory Certificate Authority was verified using certutil. The signing certificate was located in the LocalMachine\My store and its thumbprint stored as a machine-level environment variable (SIGNING_CERT_THUMBPRINT).

The application requires this variable at startup. If absent, the service fails to initialize, enforcing secure configuration compliance. Private keys remain protected in the Windows certificate store and are never exposed in application code.

5. Application Security Hardening

A code review identified a critical vulnerability in the ticket signing endpoint. The application previously allowed arbitrarily large expiration timestamps, enabling issuance of effectively permanent tickets.

- Validation logic was implemented to enforce:
- Maximum ticket validity of 30 days
- Prevention of excessive backdating
- Rejection of unrealistic expiration values

Competition-required validation logic was preserved as instructed. The vulnerability was mitigated at the ticket issuance stage without altering mandatory scenario components.

6. Blue Flag and Compliance Controls

The blue flag was placed in C:\Windows\System32 with permissions equivalent to Linux 644. Administrators and SYSTEM retain full control, while standard users have read-only access. This ensures compliance with competition scoring requirements while preventing unauthorized modification.

7. Audit Logging and Service Reduction

Audit policies were enabled to log:

- Logon/logoff events
- Privilege use
- Object access
- Account management

- Unnecessary services such as Print Spooler and Remote Registry were disabled to reduce attack surface.

8. Ticketing Machine Status
The system is fully deployed, hardened, and operational. Firewall configuration, credential security, certificate integration, vulnerability remediation, automated startup, and logging controls are all active. The machine is prepared for competition attack phase operations.

SECTION V – ADMIN USER INTERFACE REPORT

System: admin.team29.isucdc.com
Platform: Windows Server 2022
Application: Admin UI (Flask) – Port 80

System Overview

The Admin User Interface provides administrative control over the city transportation system, including fleet status monitoring and vehicle management. The application runs via the **"Admin UI" scheduled task** and is required to be accessible on:

-Port 80 (HTTP) – for Transit Admins

-Port 3389 (RDP) – for IT Administrators

The system is domain joined and integrated with Active Directory.

Credential Hardening

The default credentials (Administrator / cdc) were immediately replaced with a strong passphrase using:

net user Administrator <NewPassword>

Password change was verified via `net user Administrator`.
This mitigated default credential exploitation and brute-force risks

Service Stability and Availability

Initial assessment revealed the Admin UI did not automatically start after reboot, causing HTTP downtime and scoring failures.

The scheduled task was corrected to:

- Trigger **At Startup**
- Run whether user is logged in or not
- Run with highest privileges
- Execute under a privileged context

Post-reboot validation confirmed:

- Port 80 is listening
- Application returns valid HTTP 302 redirect to `/login`
- Service remains persistent across reboots
  CompetitionAdminUserInterface

Account and Privilege Review

Local accounts were enumerated using:

Get-LocalUser
net localgroup administrators

Unnecessary accounts were removed from the Administrators group while preserving account existence for scoring safety

SECTION VI – PUBLIC WEBSITE VULNERABILITY ASSESSMENT

System: www.public-website
Platform: Linux Server Infrastructure
Assessment Type: Post-Compromise Security Review

1. Executive Summary
A comprehensive security assessment of the public website infrastructure identified multiple critical vulnerabilities, including a kernel-level rootkit infection, privilege escalation misconfigurations, weak SSH protections, and insufficient input validation mechanisms.
Although several mitigations were implemented, the system remains at residual risk due to incomplete rootkit removal. Full trust restoration requires system rebuild and forensic validation.

2. System Scope
The public website supports authentication, user registration, and ticket purchasing routes. The backend runs on a Linux server with SSH remote access enabled. Core services include cron scheduling, authentication modules, and application runtime services.

Assessment scope included configuration auditing, source code review, kernel integrity inspection, privilege escalation analysis, SSH policy review, and cron service evaluation.

3. Critical Vulnerabilities Identified

3.1 Kernel-Level Rootkit – “Platypus”

A kernel-level rootkit named “Platypus” was identified operating at ring-0 privilege level. Capabilities include syscall interception, process hiding, network filtering, and cron-based persistence.

Risk Level: CRITICAL

The presence of kernel malware undermines system integrity and cannot be fully mitigated without reinstallation.

3.2 Passwordless Sudo Configuration

Users were configured for passwordless sudo execution. This represented immediate privilege escalation risk if any account were compromised.

Risk Level: CRITICAL

3.3 Lack of Input Validation

Authentication and purchasing endpoints lacked regex validation, exposing the system to injection attacks including SQL injection, XSS, command injection, and malformed input exploitation.

Risk Level: HIGH

3.4 SSH Brute-Force Exposure

The SSH service lacked intrusion prevention controls, allowing unlimited login attempts.

Risk Level: HIGH

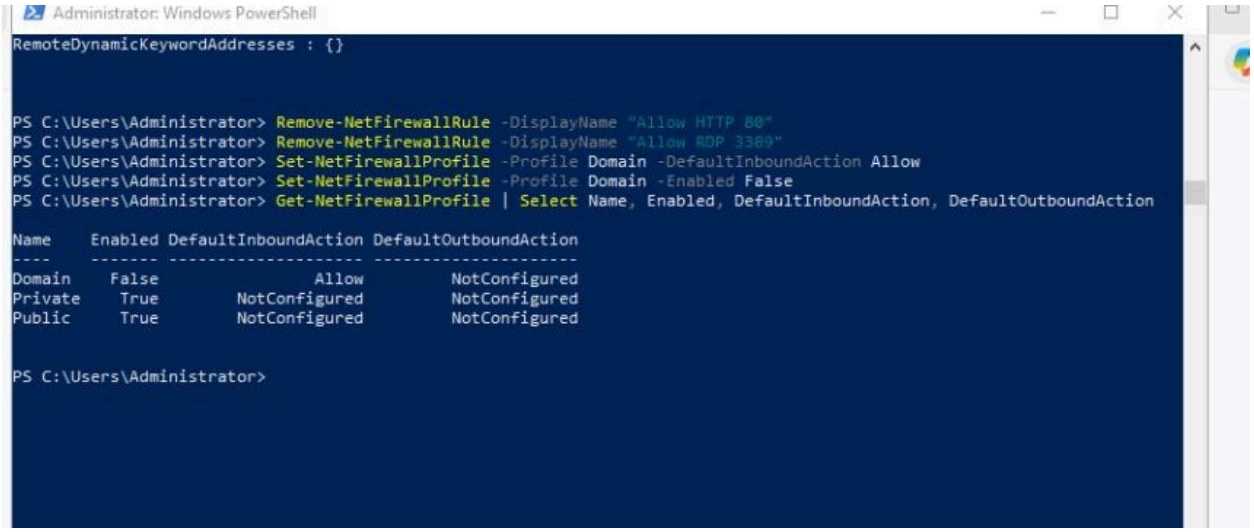
4. Remediation Measures Implemented

Mitigation steps included:

- Deployment of Fail2ban for SSH brute-force prevention
- Removal of passwordless sudo privileges
- Implementation of structured regex input validation
- Static code analysis and sanitization improvements
- Disabling suspicious cron entries
- Enhanced logging and monitoring controls

While these steps reduced operational risk, the rootkit remains present and complete eradication requires kernel reinstallation and system rebuild.

INTRUSION REPORT
Newuser

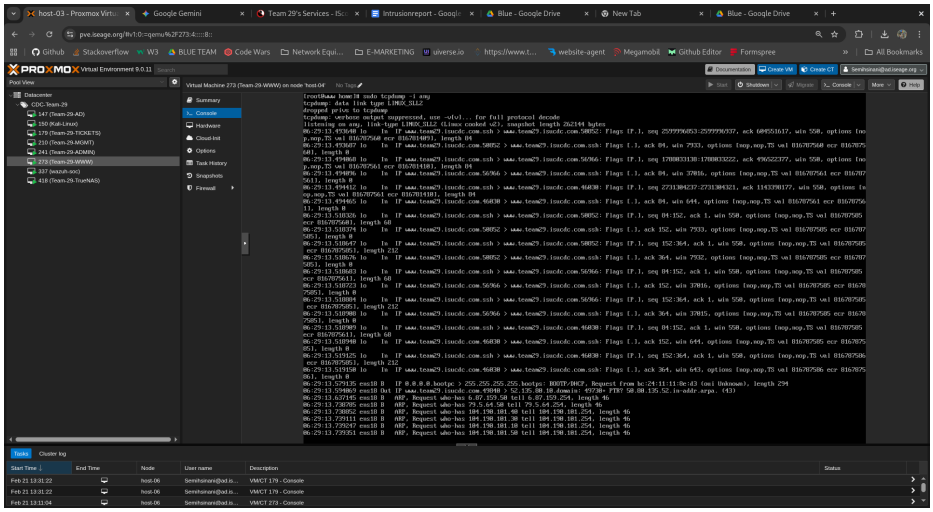


Time 13:31
2 new user created

monitoring systems detected the creation of two new user accounts without authorized administrative approval. The activity was immediately flagged as suspicious.
Simultaneously, abnormal ARP (Address Resolution Protocol) requests were observed on the network. This behavior is consistent with local network reconnaissance or potential ARP spoofing attempts.
At 13:31, an authentication request followe by a login attempt was recorded, indicating possible use of the newly created accounts.
At 13:36, the source IP address associated with this activity was identified and blocked at the firewall level.

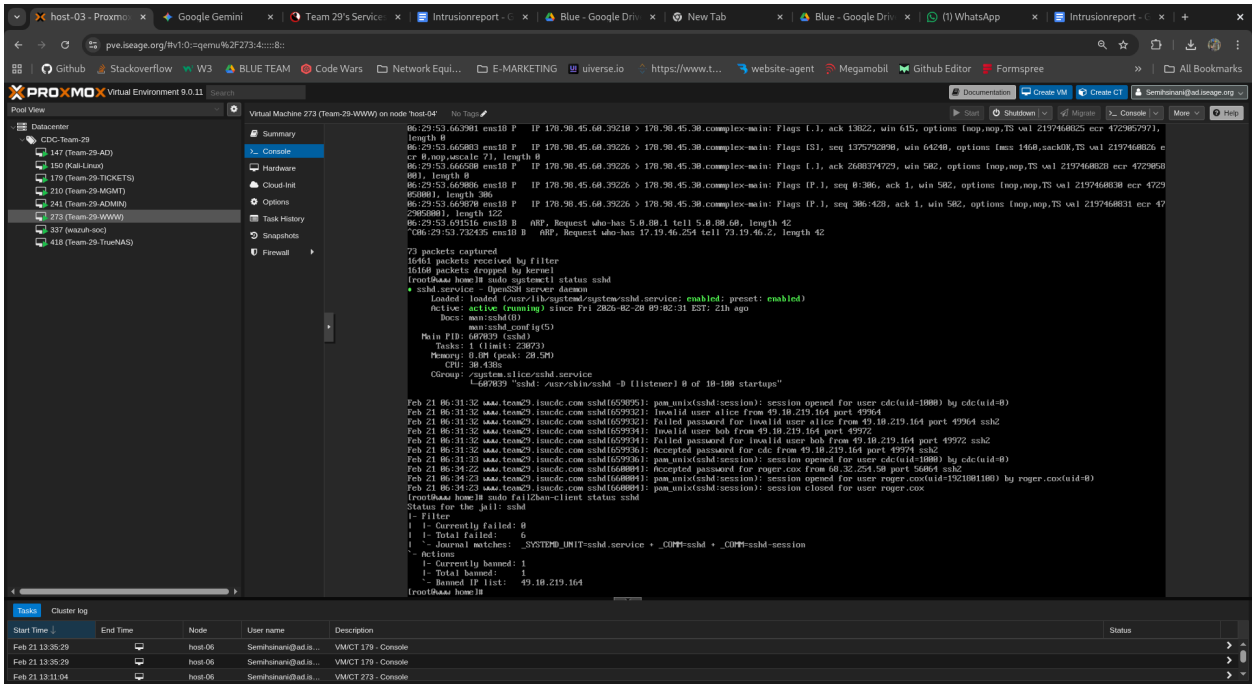
2. Technical Indicators
Unauthorized creation of 2 user accounts
ARP requests observed on local network segment
Authentication request and login attempt
Suspicious IP address identified and blocked

ARP REQUEST



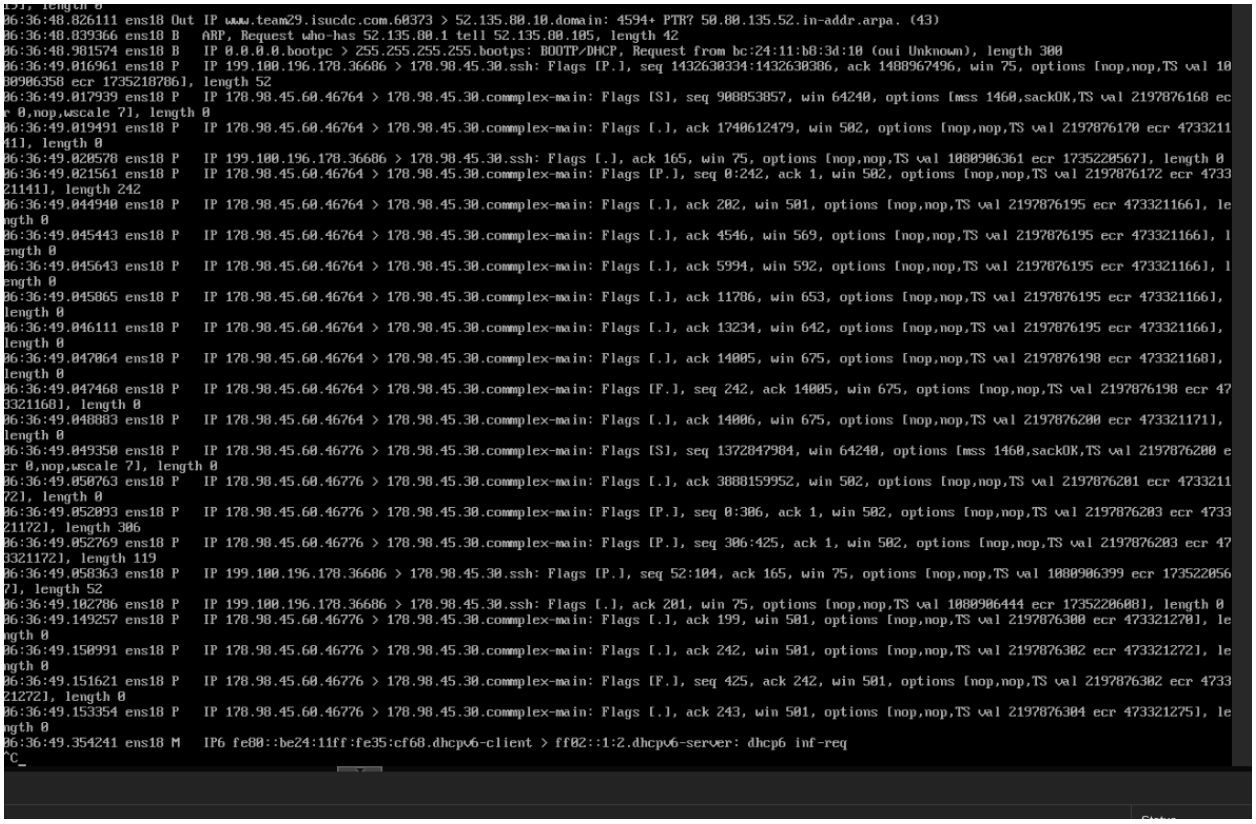
Time: 13:31
Auth Request sent
Auth Login

At **13:31**, incident detection mechanisms identified suspicious activity within the domain environment. Two new user accounts were created in Active Directory, accompanied by an observed ARP request on the network and subsequent authentication activity, including an authentication request and login event. The timing and sequence of these events indicated potential unauthorized account creation and possible domain access, triggering further investigation and security review.



13:39 new login

PORT SCANNING:



Auth login 13:44

Netbios in AD 13:47

At 13:44, an authentication login event was recorded on the Domain Controller. Shortly after, at 13:47, NetBIOS-related activity targeting Active Directory services was detected. The sequence suggests possible reconnaissance activity following or accompanying an authentication attempt.

The activity may indicate credential testing followed by network enumeration.

Ssh traffic 13:58

At **13:58**, suspicious SSH traffic was detected originating from an external source. The activity indicated an attempted remote connection to the system's SSH service, suggesting possible reconnaissance or brute-force authentication attempts. The connection was logged and monitored to determine whether it resulted in successful access. No confirmed unauthorized login was observed at the time of detection, and defensive controls remained in place to prevent further exploitation.

Logged into the system frontend 13:59

At **13:59**, a login to the system frontend was recorded. This login occurred shortly after earlier authentication and NetBIOS-related activity (13:44–13:47), increasing the likelihood of coordinated reconnaissance followed by access attempt.

The activity is considered **suspicious pending verification of the user and source IP**.

13:59 create users logged in
At **13:59**, login activity was recorded for the previously created user accounts, indicating successful authentication within the domain environment.

14:09

14:11 attempt to intrude ssh

At **14:11**, an attempted intrusion targeting the SSH service was detected, suggesting continued unauthorized access attempts against internal systems. These events were documented for investigation and response actions.